

# Arquitectura de Seguridad - Mediano Plazo (3-6 meses)

## Caso Bankitor - TO-BE

---

### 1. Punto de Partida

El mediano plazo **construye sobre lo implementado en el corto plazo**. No reemplaza; amplía y madura.

Al iniciar esta fase, Bankitor ya tiene operativo:

- Router con AAA/TACACS+, Syslog y backup de configuración.
  - Auditoría SQL en base de datos de créditos.
  - WAF activo para banca por Internet.
  - Firewall HA con segmentación DMZ / Red Interna.
  - SIEM recibiendo logs de todos los componentes críticos.
  - MFA y Bastion Host para accesos administrativos.
- 

### 2. Objetivo del Mediano Plazo

Madurar los controles existentes, mejorar la visibilidad interna, implementar detección activa de intrusiones, segmentar la red interna correctamente y elevar el control de accesos privilegiados.

**Duración:** Meses 4 al 6

**Enfoque:** Segmentación, detección, gestión de privilegios, escaneo de vulnerabilidades y continuidad operativa.

---

### 3. Nuevos Componentes Incorporados

#### 3.1 IDS / IPS - Detección y Prevención de Intrusiones

Qué es:

- **IDS (Intrusion Detection System):** Detecta y alerta sobre tráfico sospechoso.

- **IPS (Intrusion Prevention System):** Detecta y bloquea automáticamente el tráfico sospechoso.

#### **Por qué en mediano plazo:**

- En corto plazo se implementó visibilidad (SIEM) y protección perimetral (WAF, Firewall).
- El IDS/IPS agrega detección activa dentro de la red y en puntos estratégicos.
- Requiere calibración y ajuste de reglas para evitar falsos positivos, por eso no se implementa en el primer mes.

#### **Posicionamiento recomendado:**

- Entre el Firewall Perimetral y la DMZ (detecta ataques que pasen el firewall).
- Entre DMZ y Red Interna (detecta movimiento lateral).

#### **Qué detecta:**

- Escaneos de red (port scanning).
- Exploits conocidos contra servidores.
- Comunicación con IPs maliciosas (C2).
- Movimiento lateral entre zonas.
- Tráfico anómalo por protocolo.
- Intentos de escalada de privilegios.

#### **Logs al SIEM:**

- Alertas de detección con severidad.
- IP origen y destino del tráfico sospechoso.
- Firma o patrón que activó la alerta.
- Acción tomada (alerta o bloqueo).

---

## **3.2 PAM - Gestión de Accesos Privilegiados**

#### **Qué es:**

PAM (Privileged Access Management) es una plataforma que controla, audita y gestiona todos los accesos de usuarios con privilegios elevados.

#### **Por qué reemplaza al Bastion básico:**

El Bastion del corto plazo centraliza el acceso, pero un PAM agrega:

| Función                              | Bastion básico | PAM               |
|--------------------------------------|----------------|-------------------|
| Centraliza accesos                   | Sí             | Sí                |
| Graba sesiones completas             | Limitado       | Sí, video y texto |
| Rotación automática de contraseñas   | No             | Sí                |
| Control de contraseñas en bóveda     | No             | Sí                |
| Aprobación de accesos en tiempo real | No             | Sí                |
| Integración con SIEM                 | Manual         | Nativa            |
| Acceso just-in-time                  | No             | Sí                |

### Cuentas que debe gestionar el PAM en Bankitor:

- Administradores de routers y firewalls.
- DBA con acceso a base de datos de créditos.
- Administradores del servidor web.
- Administradores del SIEM.
- Cuentas de servicio de aplicaciones críticas.
- Cuentas de backup y monitoreo.

### Ejemplo de flujo con PAM:

1. Administrador solicita acceso al router DC1
2. PAM verifica identidad (MFA obligatorio)
3. PAM crea sesión temporal con contraseña rotada
4. Administrador trabaja en sesión grabada
5. Al cerrar: contraseña se rota automáticamente
6. La sesión completa queda archivada y disponible para auditoría
7. SIEM recibe el evento con todos los detalles

## 3.3 Segmentación de Red Interna (VLANs)

### Qué es:

Dividir la red interna en segmentos lógicos separados (VLANs) para aislar grupos de sistemas según su función y nivel de riesgo.

### Por qué es importante:

Si un atacante entra a la red interna (por ejemplo, mediante phishing a un usuario), no debe poder moverse libremente a todos los sistemas.

**Segmentación propuesta para Bankitor:**

| VLAN    | Nombre                | Sistemas incluidos                |
|---------|-----------------------|-----------------------------------|
| VLAN 10 | Usuarios              | PCs de empleados del banco        |
| VLAN 20 | Servidores Aplicación | Middleware, APIs internas         |
| VLAN 30 | Base de Datos         | Servidores BD de créditos y otros |
| VLAN 40 | Administración        | Bastion / PAM, SIEM, consolas     |
| VLAN 50 | Respaldos             | Servidores de backup              |
| VLAN 60 | DMZ interna           | Si se necesita zona adicional     |

**Reglas de comunicación entre VLANs:**

- Usuarios → Servidores Aplicación: permitido (puertos específicos).
- Usuarios → Base de Datos: **BLOQUEADO**.
- Servidores Aplicación → Base de Datos: permitido (puertos específicos).
- VLAN Administración → todas: permitido (solo desde Bastion/PAM).
- BD → Usuarios: **BLOQUEADO**.
- Respaldos → BD: permitido (solo en ventana de backup).

**Beneficio directo para Bankitor:**

Contiene el daño ante el compromiso de un equipo de usuario o servidor de aplicación.

---

**3.4 Gestión de Vulnerabilidades**

**Qué es:**

Proceso continuo de identificar, priorizar y remediar vulnerabilidades en los sistemas de Bankitor.

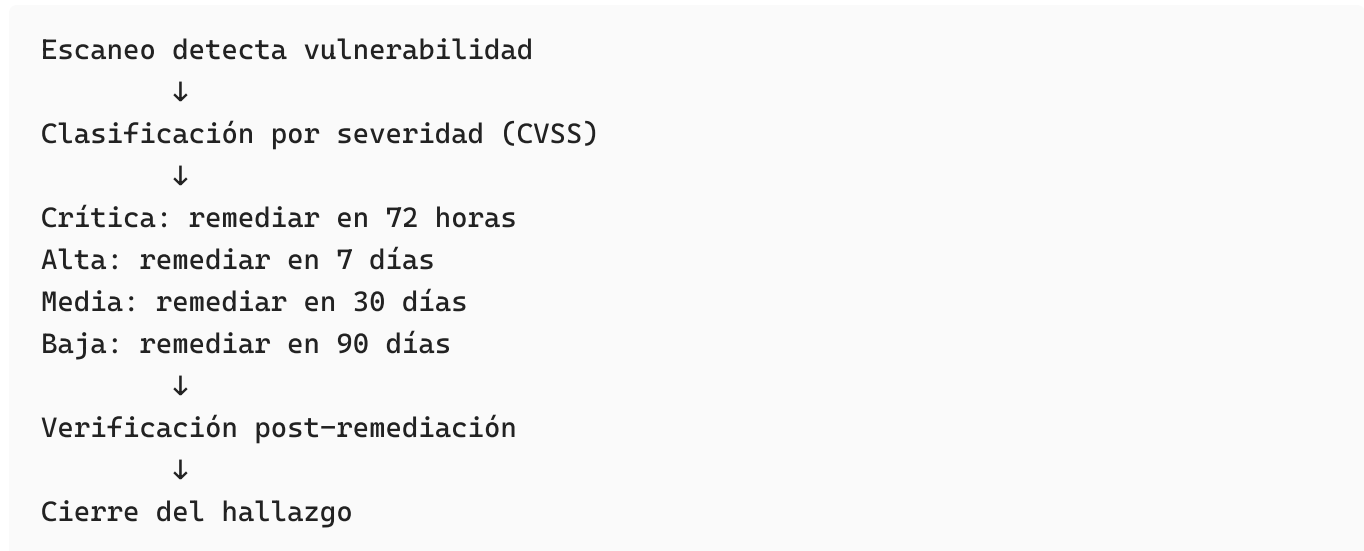
**Componentes:**

| Componente                  | Función                                           |
|-----------------------------|---------------------------------------------------|
| Escáner de vulnerabilidades | Escanea servidores, equipos de red y aplicaciones |
| Gestión de parches          | Proceso formal de aplicar parches al sistema      |
| Base de datos de activos    | Inventario actualizado de todos los sistemas      |

**Frecuencia recomendada:**

- Escaneo de servidores críticos (BD, Web): mensual como mínimo.
- Escaneo de red interna: trimestral.
- Escaneo de aplicación web: continuo (integrar con SIEM o WAF).

### Proceso de remediación:



### Relación con incidente Bankitor:

Si hubiera habido gestión de vulnerabilidades, se podría haber detectado si el software de la base de datos o el router de borde tenían vulnerabilidades conocidas antes de que ocurriera el incidente.

---

## 3.5 DLP - Prevención de Pérdida de Datos (básico)

### Qué es:

DLP (Data Loss Prevention) controla que información sensible no salga de la organización sin autorización.

### Por qué en mediano plazo:

Requiere primero clasificar los datos (saber qué es sensible) y luego aplicar controles. En corto plazo se prioriza contención; en mediano plazo se comienza a controlar exfiltración.

### Datos sensibles en Bankitor:

- Datos de clientes (nombre, DNI, datos financieros).
- Saldos de crédito.
- Contraseñas y tokens.
- Configuraciones de equipos críticos.
- Reportes financieros.

### Implementación básica en mediano plazo:

- DLP en correo electrónico: bloquear envío de archivos con datos financieros fuera del banco.
- DLP en proxy: detectar upload de archivos sensibles a servicios externos.
- Clasificación de datos: etiquetar documentos según nivel de sensibilidad.

**Evolución a largo plazo:** DLP endpoint completo, DLP en la nube, integración con SIEM para alertas de exfiltración.

---

## 3.6 Hardening de Red y Protocolos

### Qué se hace:

| Control                       | Acción                                                          |
|-------------------------------|-----------------------------------------------------------------|
| Desactivar protocolos débiles | Telnet, FTP, SSHv1, TLS 1.0/1.1                                 |
| Fortalecer SSH                | Solo SSH v2, solo claves, sin contraseñas                       |
| SNMP seguro                   | Migrar a SNMPv3 con autenticación y cifrado                     |
| DNS seguro                    | DNSSEC, filtrado DNS con RPZ                                    |
| NTP autenticado               | Sincronización de tiempo confiable (crítico para logs forenses) |
| Seguridad en switches         | Port security, DHCP snooping, Dynamic ARP Inspection            |

### Por qué NTP es crítico:

Si los relojes de los equipos están desincronizados, los logs del SIEM no se pueden correlacionar correctamente. Un atacante puede aprovechar esto. En el incidente de Bankitor, si los timestamps del router no coinciden con los del SIEM, la investigación forense se complica.

---

## 3.7 Pruebas de Continuidad Operativa / BCP

### Qué es:

Validar que los mecanismos de continuidad del negocio realmente funcionan cuando se necesitan.

### Actividades en mediano plazo:

| Actividad                        | Objetivo                                               |
|----------------------------------|--------------------------------------------------------|
| Failover del firewall HA         | Verificar que el firewall pasivo asume sin impacto     |
| Failover del balanceador HA      | Verificar continuidad de banca por Internet            |
| Conmutación de ISP               | Verificar que el enlace secundario funciona            |
| Restauración de backup de router | Verificar que se puede hacer rollback de configuración |
| Simulacro de caída de BD         | Verificar que hay réplica o respaldo recuperable       |

**Resultado esperado:**

Cada prueba debe documentar tiempo de recuperación (RTO actual) y compararlo con el objetivo (RTO deseado).

### 3.8 Programa de Concientización en Seguridad

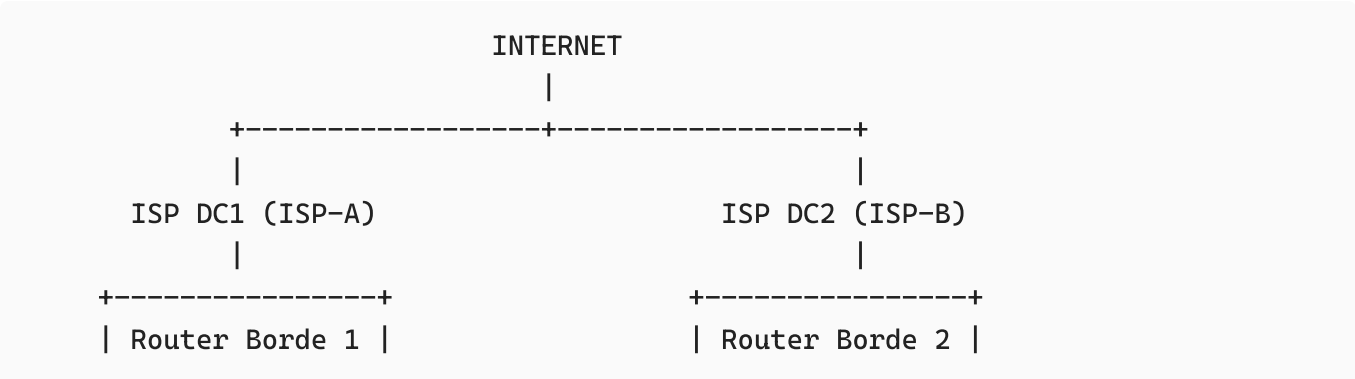
**Por qué es necesario:**

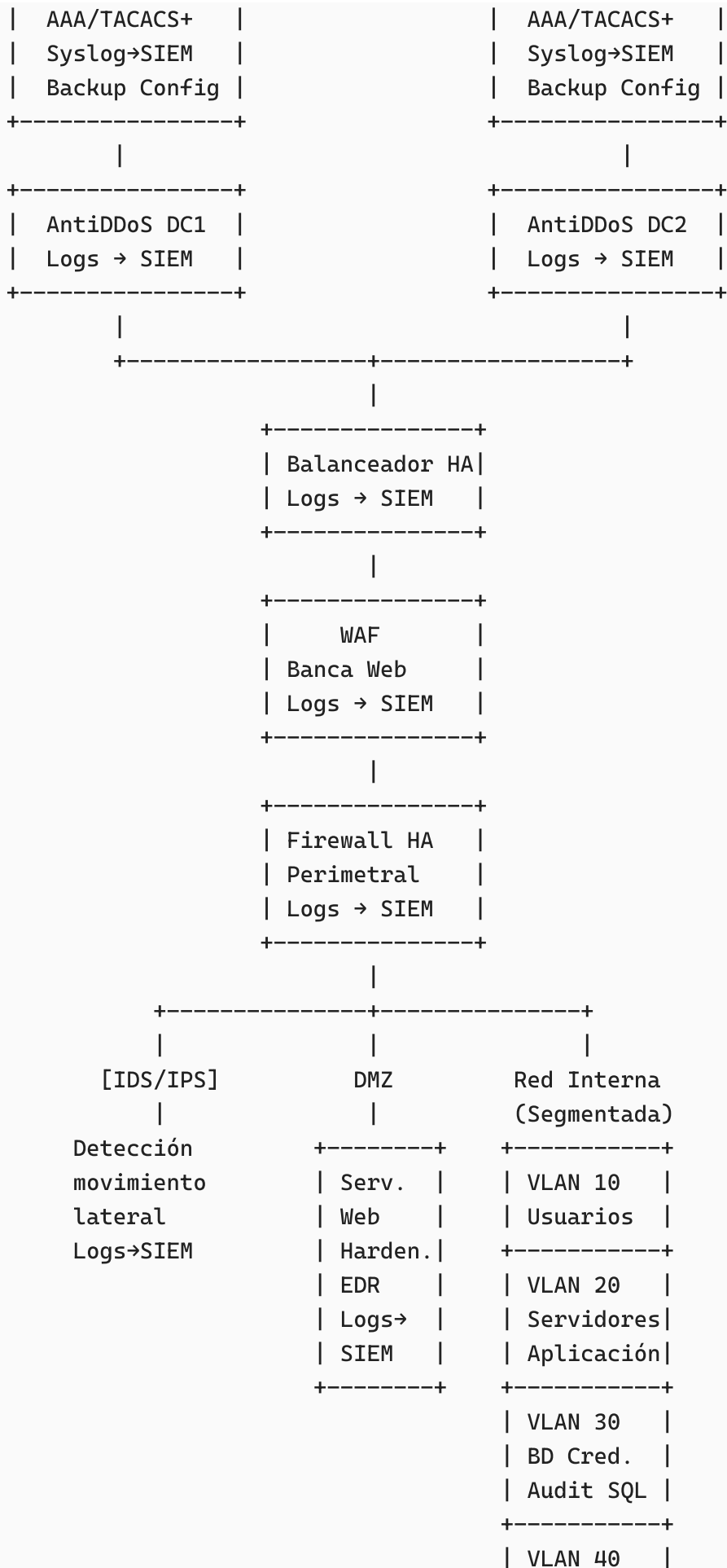
La tecnología no es suficiente. El phishing y la ingeniería social son vectores frecuentes de ataque. Un empleado bien capacitado es una capa de defensa real.

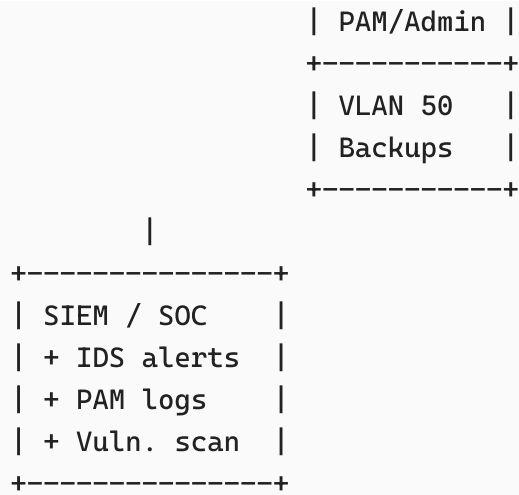
**Actividades:**

- Simulacro de phishing mensual.
- Capacitación en manejo de contraseñas.
- Guía de uso seguro del correo electrónico.
- Procedimiento de reporte de incidentes para empleados.
- Capacitación específica para DBAs sobre auditoría y control de cambios.
- Capacitación para administradores de red sobre gestión de cambios.

## 4. Diagrama General de la Arquitectura TO-BE Mediano Plazo







Administración segura:  
Admin TI → MFA → PAM → Equipos Críticos (sesión grabada, contraseña rotada)

## 5. Evolución Respecto al Corto Plazo

| Componente               | Corto Plazo          | Mediano Plazo                                  |
|--------------------------|----------------------|------------------------------------------------|
| Acceso administrativo    | Bastion básico + MFA | PAM completo + MFA + grabación de sesiones     |
| Detección de intrusiones | Solo firewall y WAF  | IDS/IPS activo en puntos estratégicos          |
| Segmentación interna     | DMZ vs Red Interna   | VLANs internas por función                     |
| Gestión de parches       | Ad-hoc               | Proceso formal con escáner de vulnerabilidades |
| Exfiltración de datos    | Sin control          | DLP básico en correo y proxy                   |
| Protocolos de red        | Sin revisión         | Hardening de protocolos (SSH, SNMP, TLS)       |
| Continuidad operativa    | Sin validar          | Pruebas de failover documentadas               |
| Capacitación             | Sin programa         | Simulacros de phishing y capacitación formal   |

## 6. Casos de Uso SIEM Nuevos en Mediano Plazo

| Caso de Uso                                  | Fuente del Log     | Severidad |
|----------------------------------------------|--------------------|-----------|
| Alerta IDS de escaneo de red                 | IDS/IPS            | Alta      |
| Tráfico sospechoso VLAN Usuarios → BD        | IDS/IPS + Firewall | Crítica   |
| Sesión PAM sin aprobación previa             | PAM                | Alta      |
| Contraseña crítica no rotada en X días       | PAM                | Media     |
| Equipo con vulnerabilidad crítica sin parche | Escáner            | Alta      |
| Upload masivo a servicio externo             | DLP + Proxy        | Alta      |
| Acceso DBA desde VLAN de Usuarios            | Firewall + IDS     | Crítica   |
| Protocolo Telnet detectado en red            | IDS                | Alta      |

## 7. Actividades del Mediano Plazo (meses 4-6)

### Mes 4

- ☐ Implementar escáner de vulnerabilidades (Nessus, Qualys o similar).
- ☐ Realizar primer escaneo de servidores críticos y red interna.
- ☐ Diseñar esquema de VLANs y validar con el equipo de redes.
- ☐ Evaluar y seleccionar solución PAM.
- ☐ Lanzar primer simulacro de phishing a empleados.

### Mes 5

- ☐ Implementar segmentación VLAN en red interna.
- ☐ Instalar y calibrar IDS/IPS en puntos estratégicos.
- ☐ Implementar hardening de protocolos (SSH, SNMP, TLS, NTP).
- ☐ Iniciar implementación del PAM.
- ☐ Comenzar clasificación de datos sensibles.

### Mes 6

- ☐ Completar integración del PAM con SIEM y MFA.
- ☐ Implementar DLP básico en correo y proxy.
- ☐ Realizar pruebas de continuidad: failover firewall, balanceador, ISP.
- ☐ Capacitación formal a DBAs y administradores de red.
- ☐ Revisar y actualizar casos de uso del SIEM con nuevas fuentes (IDS/IPS, PAM).

☐ Documentar RTO/RPO observado en pruebas.

---

## 8. Supuestos Adicionales para Mediano Plazo

1. Las VLANs se implementan sobre la infraestructura de switches existente (compatible con 802.1Q).
  2. El PAM se integra con el Directorio Activo existente (si lo hay) o con LDAP.
  3. El IDS/IPS es una solución de red (no solo de host), posicionada en los puntos estratégicos indicados.
  4. El escáner de vulnerabilidades tiene acceso de red a todos los segmentos internos.
  5. El DLP básico se implementa primero en correo y proxy; el DLP de endpoint se difiere al largo plazo.
- 

*Documento: Arquitectura de Seguridad Bankitor - Mediano Plazo (3-6 meses)*

*Clasificación: Uso interno - Trabajo académico ESAN*